Information Gathering

INE · Cybersecurity · Assessment Methodologies — Module Notes

1. Information Gathering Overview

Information Gathering (Reconnaissance) is the initial and most critical stage of any penetration test. It involves collecting as much information as possible about a target — individual, website, company or system. The more data collected, the easier and more successful later stages will be.

Attack Pipeline

PENTEST PIPELINE

Information Gathering → Enumeration → Exploitation → Post-Exploitation

E.g.1 – Website pentest: web technology, vulnerabilities, hosting IP address.

E.g.2 – Public + internal assets: gain access via web server AND harvest employee names, emails, credentials for phishing.

Passive vs. Active

Type	Definition	Authorization Required	Target Awareness
Passive	Obtain data without actively interacting with target. Uses publicly available internet resources.	No	No
Active	Obtain data by directly engaging with the target. Generates traffic logged by target.	YES — signed contract	Yes

PENTESTER'S CODE OF CONDUCT

Know your scope. Do not exceed your scope. Take responsibility.
Only hack when under signed contract.
Verify targets in writing before engagement starts.
Do a thorough and complete job. Take careful notes.
Upload evidence to a central repository immediately.
Communicate with teammates, client, and project managers.
Know your limitations. Treat all others with respect.
Own your mistakes. Include remediation suggestions when reporting.
Google first, then ask questions. Share your knowledge.
Above all, exercise common sense.

Training domain: zonetransfer.me (digi.ninja/projects/zonetransferme.php)

2. Passive Information Gathering

2.1 Website Reconnaissance & Footprinting

Footprinting is detailed reconnaissance on a specific target — more structured than general recon.

What to Look For on a Website

- IP addresses of the web server
- Hidden directories
- Names, email addresses, phone numbers, physical addresses
- Web technologies in use

host — DNS Lookup

Resolve a domain to its IP addresses and mail server.

```
$ host hackersploit.org

hackersploit.org has address 188.114.97.7
hackersploit.org has address 188.114.96.7
hackersploit.org has IPv6 address 2a06:98c1:3121::7
hackersploit.org has IPv6 address 2a06:98c1:3120::7
hackersploit.org mail is handled by 0 _dc-mx.2c2a3526b376.hackersploit.org.

# 2 IP addresses found = website is behind Cloudflare proxy
```

Also check: DNSLytics Report at dnslytics.com/domain/<target>

robots.txt — Hidden Paths

```
# Navigate to: https://hackersploit.org/robots.txt

# Disallow entries reveal paths the owner does NOT want indexed.
# /wp-content → confirms WordPress is running
# Any disallowed path is worth investigating manually
```

sitemap.xml — Site Structure

```
# Navigate to: https://hackersploit.org/sitemap.xml

# Lists all indexed pages, categories, authors.
# Provides a map of the full site structure — useful for attack surface mapping.
```

whatweb — Technology Fingerprinting (CLI)

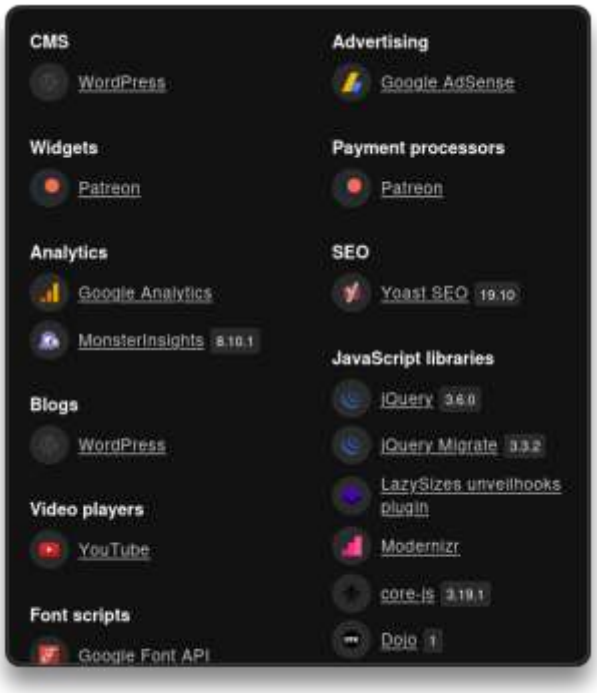
```
$ whatweb hackersploit.org

# Output example:
hackersploit.org [200 OK] Cloudflare, Country[UNITED STATES][US],
HTML5, HTTPServer[cloudflare], IP[188.114.97.7],
JQuery[3.6.0], Script, Title[HackerSploit],
WordPress[6.1.1], X-Powered-By[PHP/8.0.27]

# Reveals: CMS, JS libraries, PHP version, server software
```

Wappalyzer — Browser Add-On

Browser extension (Firefox/Chrome) that identifies the full tech stack of any website you visit: CMS, frameworks, JavaScript libraries, server headers, analytics tools, etc. Install from wappalyzer.com.



HTTrack — Website Downloader

Download an entire website locally for offline source code analysis.

```
$ sudo apt install httrack

# GUI version: open 'WebHTTrack Website Copier' from start menu
# → creates a local mirror of the entire site with all files
# → useful for analyzing PHP/JS source, finding hidden endpoints
```

2.2 Whois Enumeration

WHOIS is a query/response protocol for finding registration data of internet resources (domains, IPs, ASNs).
Returns: registration date, owner, registrar, owner email address, name servers.

```
kali@kali:~$ whois hackersploit.org
Domain Name: hackersploit.org
Registry Domain ID: 77f8fe62a425487cbefef4bf7e27d2ec-LROR
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 2022-02-05T16:01:46Z
Creation Date: 2018-04-05T11:27:07Z
Registry Expiry Date: 2023-04-05T11:27:07Z
Registrar: NameCheap, Inc.
Registrar IANA ID: 1068
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.6613102107
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Registry Registrant ID: REDACTED FOR PRIVACY
Registrant Name: REDACTED FOR PRIVACY
Registrant Organization: Privacy service provided by Withheld for Privacy ehf
Registrant Street: REDACTED FOR PRIVACY
Registrant City: REDACTED FOR PRIVACY
Registrant State/Province: Capital Region
Registrant Postal Code: REDACTED FOR PRIVACY
Registrant Country: IS
Registrant Phone: REDACTED FOR PRIVACY
Registrant Phone Ext: REDACTED FOR PRIVACY
Registrant Fax: REDACTED FOR PRIVACY
Registrant Fax Ext: REDACTED FOR PRIVACY
```

```
kali@kali:~$ whois 172.64.32.93


#
# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2022, American Registry for Internet Numbers, Ltd.
#


NetRange:       172.64.0.0 - 172.71.255.255
CIDR:           172.64.0.0/13
NetName:        CLOUDFLARENET
NetHandle:      NET-172-64-0-0-1
Parent:         NET172 (NET-172-0-0-0-0)
NetType:        Direct Allocation
OriginAS:       AS13335
Organization:   Cloudflare, Inc. (CLOUD14)
RegDate:        2015-02-25
Updated:        2021-05-26
Comment:        All Cloudflare abuse reporting can be done via https:
Ref:            https://rdap.arin.net/registry/ip/172.64.0.0
```

Online WHOIS tools: who.is | domaintools.com

2.3 Website Footprinting with Netcraft

Netcraft (netcraft.com) provides structured internet security data. Navigate to: sitereport.netcraft.com/?url=<target>

What Netcraft Reports

Section	Data Available
Background	Domain IP address, Nameserver, Domain registrar, IP delegation
SSL/TLS Certificate	Issuer, Validity dates, Transparency log, Known vulnerabilities
Hosting History	All previous hosting providers and IP addresses over time
Web Trackers	Analytics and tracking scripts embedded in the site
Site Technology	Server-Side stack, Client-Side frameworks, CMS, CDN

WHY NETCRAFT MATTERS

Hosting History reveals previous IPs — the REAL server IP may be exposed before Cloudflare was added.

SSL/TLS data flags certificate misconfigs without active scanning.

All data is aggregated passively from public sources — zero traffic to the target.

2.4 DNS Reconnaissance

DNS records map domain names to infrastructure. Enumerating them reveals IP addresses, mail servers, subdomains, and technology details.

DNS Record Types

Record	Description
A	IPv4 address of domain/hostname
AAAA	IPv6 address of domain/hostname
CNAME	Alias — forwards one domain/subdomain to another
MX	Mail server address for the domain
TXT	Admin text notes; used for SPF, DKIM, domain verification
NS	Authoritative name servers for the domain
SOA	Start of Authority — admin info and primary NS
HINFO	Host information (OS, hardware)
SRV	Service-specific records (VoIP, XMPP, etc.)
PTR	Reverse lookup — IP address → hostname

dnsrecon — DNS Record Enumeration

```
$ dnsrecon -d hackersploit.org

# Output example:
[*] NS   ns1.cloudflare.com      108.162.192.9
[*] NS   ns2.cloudflare.com      108.162.193.9
[*] A    hackersploit.org        188.114.97.7
[*] AAAA hackersploit.org        2a06:98c1:3121::7
[*] MX   _dc-mx.2c2a3526b376.hackersploit.org  188.114.97.7
[*] TXT  hackersploit.org        v=spf1 include:_spf.mx.cloudflare.net ~all

# Uses: NS Records, A/AAAA records, MX records, TXT/SPF records
# Can also brute-force subdomains with -D wordlist.txt
```

dnsdumpster.com — Visual DNS Mapping

Navigate to: dnsdumpster.com — paste in the target domain.

- Discovers all related hosts for a domain using public sources
- Exports a visual domain map as a .png image or .xlsx file
- Shows MX records, nameservers, A records — all in one view
- No installation required — entirely web-based passive tool

2.5 WAF Detection — wafw00f

Before active scanning, identify if a Web Application Firewall (WAF) protects the target. A WAF will block or distort active scan results.

```
$ wafw00f -l                        # List all ~150 detectable WAFs
$ wafw00f hackersploit.org          # Detect WAF (stops at first match)
$ wafw00f hackertube.net -a         # -a = test ALL WAF signatures
$ wafw00f zonetransfer.me -a

# Example output (WAF detected):
# [*] Checking https://hackersploit.org
# [+] The site https://hackersploit.org is behind Cloudflare (Cloudflare Inc.) WAF.

# Example output (no WAF):
# [-] No WAF detected by the generic detection
```

Detection method: (1) Normal HTTP request → analyse headers. (2) Malicious-looking payloads → deduce WAF by response. (3) Pattern-match previous responses.

2.6 Subdomain Enumeration — Sublist3r

Sublist3r is a Python OSINT tool that enumerates subdomains using public search engines and databases. This is passive — it never contacts the target directly.

Sources queried: Google, Yahoo, Bing, Baidu, Ask, Netcraft, VirusTotal, DNSdumpster, ReverseDNS, ThreatCrowd.

```
$ sudo apt install sublist3r

$ sublist3r -d hackersploit.com
$ sublist3r -d hackersploit.com -e google,yahoo   # Limit to specific engines
$ sublist3r -d hackersploit.com -o hs_subs.txt    # Save output to file
$ sublist3r -d ine.com                            # Enumerate ine.com subdomains

# Example output:
```

```
# [+] Total Unique Subdomains Found: 12
# blog.hackersploit.com
# mail.hackersploit.com
# staging.hackersploit.com     ← staging environments often less hardened
# dev.hackersploit.com         ← dev servers = high value targets
```

2.7 Google Dorking

Google Dorking uses advanced search operators to find sensitive information, subdomains, exposed files, and misconfigurations indexed by Google — all passively.

Operator	Usage	Example	What It Finds
site:	Limit to specific domain	site:ine.com	All indexed pages + subdomains
site:	Search within domain + keyword	site:ine.com employees	Staff names, org charts
inurl:	Match URL path/title	site:ine.com inurl:admin	Admin panels, login pages
site:*.domain.com	List all subdomains	site:*.ine.com	All exposed subdomains
intitle:	Match page title	site:*.ine.com intitle:forum	Subdomains with word in title
filetype:	Restrict to file type	site:*.ine.com filetype:pdf	Exposed PDFs, docs, configs
intitle:index of	Directory listings	intitle:index of	Open directory listings
cache:	Cached/previous version	cache:ine.com	Old versions, deleted content
inurl:auth_user_file.txt	Exposed auth files	(direct)	Apache password files
inurl:passwd.txt	Exposed password files	(direct)	Password file exposure
inurl:wp-config.bak	Exposed WP configs	(direct)	WordPress DB credentials

GOOGLE HACKING DATABASE

exploit-db.com/google-hacking-database — a searchable database of working dorks organized by category.
Categories include: Sensitive Directories, Files Containing Passwords, Vulnerable Servers, Error Messages, Web Server Detection, Default Credentials pages, and more.
Always search GHDB first before crafting dorks from scratch.

Wayback Machine — Historical Snapshots

archive.org/web — the Wayback Machine captures snapshots of websites over decades.

- Check older versions of the target site for leaked credentials, removed pages, old endpoints
- Old admin portals, staging links, API keys in JS files may have been removed but remain in archives
- Older emails are more likely to appear in breached databases — useful for next step

2.8 Email Harvesting — theHarvester

theHarvester is a pre-installed Kali Python tool for OSINT email and subdomain enumeration from public sources. Emails found can be used in phishing attacks with malicious attachments.

```
$ theHarvester -d hackersploit.org
$ theHarvester -d hackersploit.org -b dnsdumpster,duckduckgo,crtsh
$ theHarvester -d zonetransfer.me -b all     # Use ALL available sources

# Example output:
# [*] Emails found: 3
# info@hackersploit.org
# support@hackersploit.org
# alex@hackersploit.org

# [*] Hosts found: 7
# blog.hackersploit.org:188.114.97.7
# mail.hackersploit.org:188.114.97.8
# staging.hackersploit.org:198.51.100.12
```

Data sources include: Google, Bing, DuckDuckGo, Baidu, LinkedIn, Twitter, crt.sh, DNSdumpster, Shodan, and more.

2.9 Leaked Password Databases — HaveIBeenPwned

Email addresses discovered through harvesting can be checked against known data breach databases to find leaked passwords for password spray attacks.

```
# Navigate to: haveibeenpwned.com
# → Enter discovered email address
# → Returns list of breaches the email appeared in

# Example (clean):
# Good news — no pwnage found!

# Example (breached):
# Oh no — pwned!
# Pwned in 3 data breaches:
# Adobe (2013): 153M accounts — Passwords stored as MD5
# LinkedIn (2012): 164M accounts — SHA1 unsalted
# MySpace (2008): 360M accounts — SHA1 unsalted
```

PASSWORD SPRAY ATTACK

Take leaked passwords from breaches and test them against discovered services:
SSH, FTP, VPN, web application login portals, email (OWA), etc.
People reuse passwords across services — older emails = higher breach probability.
This step bridges passive recon into active exploitation.

3. Active Information Gathering

Active gathering requires authorization. The target will detect or log this activity. Always confirm written permission before proceeding.

3.1 DNS Zone Transfers

A zone transfer (AXFR) is a DNS mechanism for replicating zone files from a primary DNS to secondary DNS servers. When misconfigured, it leaks the ENTIRE DNS zone — all subdomains, internal IPs, and records.

- Zone transfers are rare in modern environments — but when found, they are critical severity
- Reveals internal IP addresses, hidden subdomains, VPN addresses, office locations
- Can expose the full internal network architecture of the organization

dnsenum — Automated Zone Transfer + Brute Force

```
$ dnsenum zonetransfer.me

# ── PASSIVE SECTION ──────────────────────────────────────
zonetransfer.me.  5 IN A 5.196.105.14        # Web server IP

# Name Servers:
nsztm2.digi.ninja.  5 IN A 34.225.33.2
nsztm1.digi.ninja.  5 IN A 81.4.108.41

# Mail Servers (MX):
ASPMX.L.GOOGLE.COM.  5 IN A 108.177.119.27

# ── ACTIVE: Zone Transfer ────────────────────────────────
# Trying Zone Transfer for zonetransfer.me on nsztm1.digi.ninja ...

zonetransfer.me. 7200 IN SOA nsztm1.digi.ninja. robin.digi.ninja.
zonetransfer.me. 7200 IN A 5.196.105.14
zonetransfer.me. 300 IN HINFO 'Casio fx-700G' 'Windows XP'

# Internal/sensitive records exposed:
canberra-office.zonetransfer.me. 7200 IN A 202.14.81.230  # ← office IP
dc-office.zonetransfer.me.       7200 IN A 143.228.181.132 # ← DC IP
vpn.zonetransfer.me.             4000 IN A 174.36.59.154   # ← VPN server
internal.zonetransfer.me. 300 IN NS intns1.zonetransfer.me.
intns1.zonetransfer.me.   300 IN A 81.4.108.41   # ← internal NS

# Contact info in TXT records:
contact.zonetransfer.me. TXT 'Remember to call Pippa on +44 123 4567890 or
pippa@zonetransfer.me'

# ── BRUTE FORCE: Subdomain discovery ─────────────────────
office.zonetransfer.me.  5 IN A 4.23.39.254
owa.zonetransfer.me.     5 IN A 207.46.197.32      # ← Outlook Web Access
vpn.zonetransfer.me.     5 IN A 174.36.59.154

# dnsenum fails on Cloudflare-protected NS — zone transfer disabled
```

dig — Manual Zone Transfer

```
$ dig axfr @nsztm1.digi.ninja zonetransfer.me

# axfr  = full zone transfer request
# @ns   = send query to this specific nameserver
# Output is identical to dnsenum zone transfer section

# If zone transfer is disabled:
# ; Transfer failed.
# ; AXFR query to nsztm1.digi.ninja for zonetransfer.me failed: NOTAUTH
```

fierce — DNS Recon + Subdomain Scan

```
$ fierce --domain zonetransfer.me

# Output example:
NS: nsztm2.digi.ninja. nsztm1.digi.ninja.
SOA: nsztm1.digi.ninja. (81.4.108.41)
Zone: failure                   # Zone transfer was blocked here
Wildcard: failure
```

```
# Hostnames discovered via brute force:
Found: email.zonetransfer.me.  (74.125.206.26)
Found: home.zonetransfer.me.   (127.0.0.1)
Found: office.zonetransfer.me. (4.23.39.254)
Found: owa.zonetransfer.me.    (207.46.197.32)

# Nearby IPs (reverse lookup):
{'74.125.206.21': 'wk-in-f21.1e100.net.'}
```

ZONE TRANSFER KEY INSIGHT

"Zone transfers are rare these days, but they give us the keys to the DNS castle."

Internal IPs in zone files are a critical finding — they reveal the internal network architecture.
Subdomains like owa., vpn., dc., staging. are high-value attack targets.
Always attempt zone transfer against every discovered nameserver before active port scanning.

3.2 Host Discovery with Nmap

Ping Sweep — Find All Live Hosts on a Network

The -sn (ping scan) combines: ICMP echo request + TCP SYN to port 443 + TCP ACK to port 80 + ICMP timestamp. Must run as sudo.

```
# First: identify your local network
$ ip -br -c a
lo       UNKNOWN  127.0.0.1/8
eth0     DOWN
eth1     UP       192.168.31.128/24   ← current subnet

# Run ping sweep across entire subnet
$ sudo nmap -sn 192.168.31.0/24

# Output:
Nmap scan report for 192.168.31.2          # Default Gateway
Host is up (0.00021s latency).
MAC Address: 00:50:56:F3:CD:3F (VMware)

Nmap scan report for 192.168.31.133        # Ubuntu VM
Host is up (0.00013s latency).
MAC Address: 00:0C:29:C9:89:DE (VMware)

Nmap scan report for 192.168.31.254        # VMware DHCP server
Host is up (0.00013s latency).
MAC Address: 00:50:56:E7:B4:64 (VMware)

Nmap scan report for 192.168.31.128        # Kali VM (self)
Host is up.

Nmap done: 256 IP addresses (4 hosts up) scanned in 2.01 seconds

# Copy found IPs for use in port scanning phase
```

netdiscover — ARP-Based Host Discovery

Uses ARP requests instead of ICMP — works even when ICMP is blocked. More reliable on local LANs.

```
$ netdiscover -i eth1 -r 192.168.31.0/24

# -i = network interface
```

```
# -r = IP range to scan
# -p = passive mode — only sniff, send nothing

# Output:
 IP              At MAC Address     Count  Len  MAC Vendor
 ─────────────────────────────────────────────────────────
 192.168.31.2    00:50:56:F3:CD:3F     1   60  VMware, Inc.
 192.168.31.133  00:0C:29:C9:89:DE     1   60  VMware, Inc.
 192.168.31.254  00:50:56:E7:B4:64     1   60  VMware, Inc.
```

3.3 Port Scanning with Nmap

Core Scanning Flags

Flag	What It Does
nmap <ip>	Default: ICMP ping + top 1,000 TCP ports
-Pn	Skip host discovery — treat as alive. ESSENTIAL for Windows targets.
-p <ports>	Scan specific ports. Use -p- for all 65,535.
-F	Fast mode — top 100 ports only
-sV	Service/version detection — exact software name and version string
-sC	Run default NSE scripts (banner, auth methods, vuln checks)
-A	Aggressive: combines -sV + -sC + OS detection + traceroute
-O	OS detection via TCP/IP fingerprinting. Add --osscan-guess to force.
-sS	SYN/stealth scan — sends SYN, reads reply, resets. Less logged.
-sU	UDP scan — checks DNS(53), SNMP(161), TFTP(69). Slow but needed.
-T<0-5>	Timing: T4=fast/aggressive, T3=default, T1=stealthy, avoid T5
-v / -vv	Verbose — shows results in real-time during scan
-oN <file>	Save output in normal text format
-oX <file>	Save output as XML — required for Metasploit db_import
-oA <base>	Save in all three formats simultaneously (.nmap, .xml, .gnmap)

Scanning a Windows Target

```
# Step 1 — Default scan FAILS (Windows blocks ICMP by default)
$ nmap <WIN_TARGET_IP>
# Result: 'Note: Host seems down.' — do NOT stop here

# Step 2 — Skip ping with -Pn — target revealed as alive
```

```
$ nmap -Pn <WIN_TARGET_IP>

# Output:
PORT      STATE  SERVICE
80/tcp    open   http           # ← Webserver
135/tcp   open   msrpc
139/tcp   open   netbios-ssn   # ← SMB
445/tcp   open   microsoft-ds  # ← SMB
3389/tcp  open   ms-wbt-server # ← RDP
49154/tcp open   unknown
49155/tcp open   unknown
# ^^ Classic Windows O.S. port fingerprint
```

Service Version Detection — -sV

```
$ nmap -Pn -F -sV <TARGET_IP>

# Output:
PORT      STATE  SERVICE    VERSION
80/tcp    open   http       HttpFileServer httpd 2.3
135/tcp   open   msrpc      Microsoft Windows RPC
139/tcp   open   netbios-ssn Microsoft Windows netbios-ssn
445/tcp   open   microsoft-ds Microsoft Windows Server 2008 R2 - 2012
3389/tcp  open   ssl/ms-wbt-server?
49154/tcp open   msrpc      Microsoft Windows RPC

# HFS 2.3 → searchable in Exploit-DB and CVE databases
# Microsoft Windows Server 2008 R2 → EternalBlue candidate
```

OS Detection — -O

```
$ sudo nmap -Pn -F -sV -O <TARGET_IP>

# Output:
Warning: OSScan results may be unreliable...
Device type: general purpose
Running: Microsoft Windows 2012
OS CPE: cpe:/o:microsoft:windows_server_2012
OS details: Microsoft Windows Server 2012

# CPE string → directly searchable in NVD/CVE databases
# Use --osscan-guess if detection is inconclusive
```

Default Script Scan — -sC

```
$ nmap -Pn -F -sV -O -sC <TARGET_IP>

# Example script results on port 80 (HFS):
80/tcp open  http  HttpFileServer httpd 2.3
|_http-favicon: Unknown favicon MD5: 759792EDD4EF8E6BC2D1877D27153CB1
| http-methods:
|_  Supported Methods: GET HEAD POST
|_http-server-header: HFS 2.3
|_http-title: HFS /

# Example script results on port 445 (SMB):
| smb-security-mode:
| account_used: guest
| authentication_level: user
| challenge_response: supported
```

```
|_ message_signing: disabled (dangerous, but default)
| smb2-time:
|   date: 2023-01-20 22:58:03
|_  start_date: 2023-01-20 22:27:50
```

Aggressive Scan — -A

```
$ nmap -Pn -F -A <TARGET_IP>

# Combines: -sV + -sC + -O + traceroute
# Most comprehensive single-command scan
# Generates significant traffic — use -T2 for stealth
```

UDP Scan — -sU

```
$ nmap -Pn -sU <TARGET_IP>

# ALWAYS run UDP — default nmap scans are TCP only
# Key UDP services:
# 53  = DNS
# 161 = SNMP (community strings, network info)
# 69  = TFTP
# 123 = NTP
# 500 = IKE (VPN)

# UDP is slow — results may take minutes
```

Timing Templates — -T#

Flag	Name	Use Case
-T0	Paranoid	Maximum IDS evasion, very slow
-T1	Sneaky	Slow, possible IDS evasion
-T2	Polite	Less bandwidth impact, slow — use with -A for stealth
-T3	Normal	Default scan speed
-T4	Aggressive	Fast — modern reliable networks. Recommended for CTF/lab
-T5	Insane	Fastest — avoid, may miss open ports

Output Formats — -o

```
$ nmap -Pn -F <TARGET_IP> -oN outputfile.txt    # Normal text output
$ nmap -Pn -F <TARGET_IP> -oX outputfile.xml    # XML — for Metasploit db_import
$ nmap -Pn -A -T4 <TARGET_IP> -oA full_scan     # All 3 formats at once

# -oA creates: full_scan.nmap  full_scan.xml  full_scan.gnmap
# Always save output — you will need to reference it later
```

4. Quick Reference — All Tools

Tool	Type	Command / Usage	Key Output
host	Passive	host <domain>	IP addresses, mail server
whois	Passive	whois <domain|IP>	Registrant, dates, name servers
whatweb	Passive	whatweb <url>	Full tech stack fingerprint
wafw00f	Passive	wafw00f <domain> -a	WAF type and vendor
dnsrecon	Passive	dnsrecon -d <domain>	All DNS records (A/MX/NS/TXT)
dnsdumpster	Passive	dnsdumpster.com (web)	DNS map, host relationships
sublist3r	Passive	sublist3r -d <domain>	Subdomains via OSINT
theHarvester	Passive	theHarvester -d <domain> -b all	Emails, subdomains, IPs
HaveIBeenPwned	Passive	haveibeenpwned.com (web)	Breach history for emails
HTTrack	Passive	httrack (GUI)	Full local website copy
dnsenum	Active	dnsenum <domain>	DNS records + zone transfer
dig	Active	dig axfr @<ns> <domain>	Raw zone transfer output
fierce	Active	fierce --domain <domain>	Subdomains + nearby hosts
nmap -sn	Active	nmap -sn <subnet>/24	All live hosts (ping sweep)
netdiscover	Active	netdiscover -i eth1 -r <range>	Live hosts via ARP
nmap -sV	Active	nmap -Pn -sV -A -oA out <ip>	Ports, services, OS, scripts

EXAM-READY CHECKLIST

[ ] Always use -Pn on Windows targets — ICMP is blocked by default.
[ ] Passive first: host → whois → whatweb → dnsrecon → sublist3r → theHarvester.
[ ] Check robots.txt and sitemap.xml on every web target.
[ ] Detect WAF with wafw00f before any active scanning.
[ ] Attempt DNS zone transfer (dnsenum / dig axfr) against every nameserver.
[ ] Run BOTH TCP (nmap default) and UDP (-sU) port scans.
[ ] Use -oA to save all scan formats — XML is required for Metasploit db_import.
[ ] Feed harvested emails into HaveIBeenPwned → use leaked passwords for spraying.
[ ] Check Wayback Machine for older site versions with sensitive data.
[ ] Subdomains like vpn., owa., staging., dev. are high-priority attack targets.